



Adsense Scam

A new email scam threatens website owners with a flood of bot traffic, which will kick them off Google AdSense. <https://dgit.in/mar20-19>



No FB in SG

The Singapore government has decided to block access to Facebook, and Facebook is not happy. <https://dgit.in/mar20-20>

about (*cough* cron jobs *cough*)

- **Staying informed:** Security is an ever-transient field. People are discovering loopholes, exploits are being written. This happens on a daily basis. Stay informed about the technologies you are using and their impact on the web application.

Following the above ensures the best security you can get. But remember, these are not one time steps. These are periodical activities, that's why big organisations hire whole teams to ensure that their applications are secure. When on the Internet, treat every input as malicious and every user a potential adversary. When defending crucial information, a bit of fear is necessary and leads to better fortification, but remember - you are never secure enough.

BUG BOUNTIES

Now that you have secured your web application and perfected your web security skills, let's take it a notch further. Don't be surprised when we tell you that big corporations are saying "Come hack us!" with open arms. Yes, you heard it right! Everyone is embracing the hacker culture and freelance white hat hacking industry is booming. HackerOne, one of the leading Bug Bounty platforms, has had \$110 million in funding now with an estimated \$3.8 million yearly revenue. That's just a single platform! And the hackers are paid for each bug they report. So, you earn money while hacking? Who would have thought, but the answer is yes. The 90s underground would have been proud.

Leading platforms:

Here's a list of the hacker-powered public bug-bounty and pentest platforms. We have included the ones having a demonstrated history of well-reputed programs and compensation to hackers, and are respected in the community.

- **HackerOne [www.hackerone.com]:** One of the earliest bug bounty platforms, they can very well be called the industry disruptors. Founded in 2012 by two hackers who were on a mission to hack the Top 100 firms. While most firms ignored their

reports, Facebook came forward and took the initiative and hence HackerOne was born. And now, after 8 years and \$31 million in paid bounties, it's stronger than ever. The website has public programs from reputed companies, ranging from PayPal to GitHub, Hyatt Hotels to government agencies. Bounty rate and severity are determined by the companies, and the payment is only done if the bug is deemed worthy enough and is not duplicate. The web interface is extremely user friendly and the programs are explained in minute details, with information about out-of-scope vulnerabilities, guidelines on submission and safe harbour guidelines in case the company, in whose program you are trying to find vulnerabilities in, decides to sue you. You can start right now, just sign up and hack away.

- **BugCrowd[www.bugcrowd.com]:** Alongside HackerOne, BugCrowd was the earliest entrant into public bug bounty platforms. Advertised to the corporations as "Your Elastic Security Team", the diversity in program is impressive. Similar to HackerOne, a list of programs is provided with details. Some programs are "points only", meaning they don't provide bounties but points which can be exchanged for swag(stickers, t-shirts, mugs, etc) on the BugCrowd website. Programs either provide full safe harbour or partial safe harbour. Here also there are no restrictions on signing up, you can start as soon as you want.
- **Intigriti[www.intigriti.com]:** Europe-focused platform, with a hacker community having security experts from all over the world. Intigriti has all the features that other platforms have and then some. A leaderboard is present which showcases the best hackers on the platform. Their community involvement is excellent. BugBytes is their weekly newsletter, showcasing the hot trends, vulnerabilities, curated list of articles and write-ups and a great assortment of everything web-

application security. Once in a while, they put a CTF kind of question on their Twitter handle, where you need to find a vulnerability present in the given code or interface. Winner gets an invite to a private program. It's a pretty good way to communicate with the community and in turn you get to test your skills.

- **Synack[www.synack.com]:** Synack was founded in 2013 by two former NSA agents. Following the same model as the other platforms, Synack is a trusted crowdsourced platform. A special team of freelance hackers, called Synack Red Team is present where members get to work on high paying programs with less competition. But it's an invite only club, where you need to prove your mettle before Synack spots you and you get an invitation. Other than that, there are numerous public programs where you can try your skills.

As we talked about private programs in the Synack part, all other platforms also have private programs. These are invite only, but extremely hard to get in. The benefits here are the competition is less, more vulnerabilities can be discovered with less chances of them being duplicate entries. But only after you have some bounties to your name already, you'll get the invite. So keep hustling, there's money to be made.

Learning Resources:

- Intigriti Hackademy[<https://go.intigriti.com/hackademy>]
- Hacker101[<https://www.hacker101.com/>]
- BugCrowd University[<https://www.bugcrowd.com/hackers/bugcrowd-university/>]
- Web Security Academy[<https://portswigger.net/web-security>]

Congratulations, you are now a hacker (or a web application security analyst, if you want to sound more professional). From scripting and securing web applications of your own to freelancing and breaking into big corporations to get paid, there's a whole vibrant world of ethical hacking waiting for you. Happy Hacking! 🚩